Mahdi Alhakim

Beirut, Lebanon · Open to relocating · U.S. citizen, no sponsorship needed
+961 81 927 681 · mahdi.a.alhakim@gmail.com · github.com/mahdi-al-hakim · linkedin.com/in/mahdi-alhakim

Security researcher on AI agents and identity systems, and an engineer who ships MCP and agent tooling. Building for external clients since 2022. A lot of what I find is the same bug in a different system: a check that reports success when it never actually looked.

AI evaluation and red-team tooling

- **microsoft/RAMPART #141** (merged, breaking change): a safety probe asserting the agent does not exfiltrate was passing while it exfiltrated every turn, because a tool-only adapter cannot observe side effects. I filed #140, then the fix: evaluators now return UNDETERMINED when they cannot see the evidence they judge. 4 public APIs changed, ∼300 tests added; merged by the maintainer after 34 commits and 40 review comments.
- **microsoft/PyRIT #2320** (merged, approved by the project lead, released in v1.1.0): added a reset hook so realtime and WebSocket targets close a conversation's connection after each attack.
- **inspect_petri #130** (open): for Petri, Anthropic's alignment-auditing tool now run by Meridian Labs, an eval seed where a tool result tries to make the agent exfiltrate credentials, plus a judge dimension scoring how readily it falls for it. Pilot of 9 samples: Haiku 4.5 scored 8 or 9 on 4 of 5 runs, Opus 4.6 and Fable 5 on 0 of 2. Too few to be a rate.
- **controlarm** (github.com/mahdi-al-hakim/controlarm): a red-team harness built around trustworthy negatives. A run whose positive control never fired is recorded VOID, not "no bug found". Its prior-art gate is scored against 80 labelled items from three public advisory corpora, under a rule written before the corpus was built. 1,275 tests; 180 guards, each neutered in CI to prove a test catches it.

Security research

- **Keycloak**, 3 reports, all credited. **#51630** (fixed, backported to `release/26.8`): the admin access report said a delegated admin's permission was denied while enforcement allowed the write. **#51376** (CWE-613): revoking an OAuth2 token ended the session but skipped the CAEP session-revoked event, so offline checks kept accepting it until expiry; fixed on main by PR #51386. **#51718**: a client could widen its own JWT-grant audience allowlist through dynamic registration; I wrote the fix (PR #51720). Writeup.
- **github/github-mcp-server #3109** (shipped in v1.10.0): `pull_request_read` dispatches nine methods from one switch; seven return user-written text and lockdown covered six. Untrusted fork commit messages still reached the agent through `get_commits`. One of three credited reporters. Writeup.
- **Unidata netcdf-c #3421** (open): integer overflow in classic-format length math undersized a heap buffer while the unwrapped count still drove the read loop. The project is on OSS-Fuzz; its only harness never read an attribute. Reported privately; wrote the fix at the maintainer's request. Writeup.

Experience

CME Offshore SAL, Software Engineer Jul 2025 – Present (intern 2024)

Builds software for external clients.

- Took my own proof of concept to a multi-tenant MCP server (two-engineer build) that gives clients' coding agents SDLC instructions (QA, sprint KPIs, program management, cloud cost) through Jira, Confluence, GitHub and Zephyr. Pitched it to our CEO, then owned it through deployment into 8+ client environments. Designed the security model: tenant isolation, auth, and untrusted ticket text reaching agents.
- **Architected and led development of an MCP server for our platform, and of the agentic system built on it**, replacing a customer-facing agent that looped on attempts to call platform APIs and surfaced its own failures to users.
- Replaced a rushed design that passed a high-privilege token through an iframe: had a least-privilege client provisioned, built authorization-code flow with PKCE and refresh across the app's different hosts, and recorded the auth architecture and the alternatives in the ticket.
- Owned development of an analytics dashboard whose agentic visualisation engine sits on deterministic, strictly validated computation, so data integrity never depends on the model. Architected the new micro-bundling front-end architecture with security designed in, and co-led the effort to make our repositories AI-enabled.
- Built a vulnerability-monitoring tool (NVD, OSV, CISA KEV, EPSS) that ranks dependencies and alerts via Microsoft Teams. Co-started the team's security audit workflow; ship features on AWS (serverless, EKS) in Python, Java and TypeScript; take on-call shifts.

CloudGate Consulting, Full Stack Developer (part-time, client-facing) Jul 2022 – Jul 2024

Built Flask and React apps and microservices with OpenAPI docs for client systems.

CTF, teaching and community

- **Semicolon**, Lebanese Universities CTF 2025 (∼260 teams): 1st in the national qualifying round with a three-person AUB team. Lebanon CTF 2026: co-organizer and mentor; designed and taught the official 10-session AI security course (OWASP LLM Top 10, MITRE ATLAS, prompt injection, MCP security).
- **Hack The Box Ambassador, Beirut** (Feb 2025 – Present): co-founded HTB Beirut; run 12+ meetups (20–100 people) and author practice machines. Published WeSecure, a boot-to-root VM with a full writeup.

Education and skills

American University of Beirut, B.E. Computer and Communications Engineering, 2021–2025. **Skills:** Python, C/C++, TypeScript, Java, SQL; AWS, Kubernetes; Burp Suite, ASan, PyRIT, RAMPART, Inspect.